



POKROČILE TECHNIKY V KYBERNETICKÉ BEZPEČNOSTI

Ing. Miroslav Bureš



Obsah

- IDS a IPS systémy
- SIEM systémy
- Penetrační testování
- Zdroje informací v kybernetické bezpečnosti
- Získávání dat a jejich analýza
- AI v kybernetické bezpečnosti
- Bezpečné programování
- Standart ISO/IEC 27000

IDS A IPS SYSTÉMY

IDS/IPS



Firewall versus IDS/IPS

- Firewall je jen filtr
 - Neodliší nelegitimní provoz od legitimního
 - Neochrání před bezpečnostními problémy vzniklými uvnitř sítě
 - Nelze se „zazdít“
 - servery musí poskytovat služby
 - uživatelé je chtějí využívat

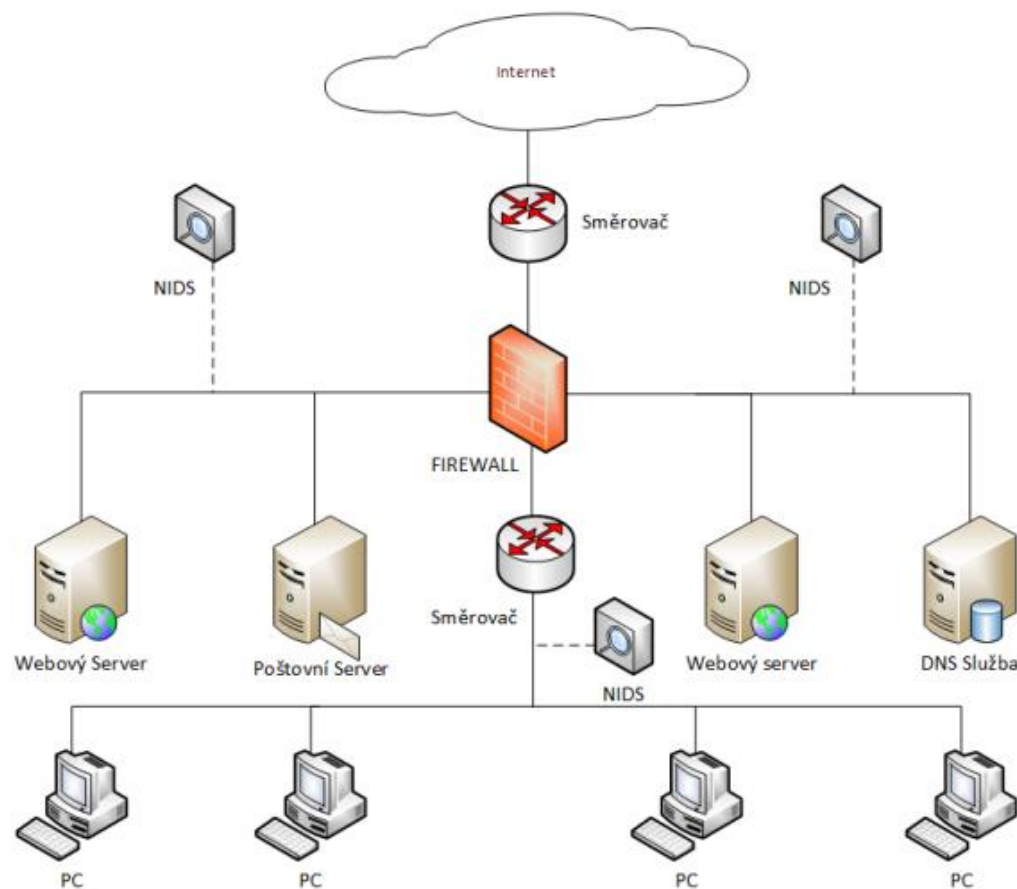
IDS x IPS

- Inspection Detection Systém
 - Přijímá klonovaný provoz (SpanPort / TAPbox)
 - Informuje správce sítě či konkrétního stroje
 - Je pasivní, nezasahuje do provozu
- Inspection Prevention Systém
 - Zařízení umístěné v lince
 - Informuje správce, navíc blokuje nežádoucí komunikaci
 - Je aktivní, zasahuje do provozu

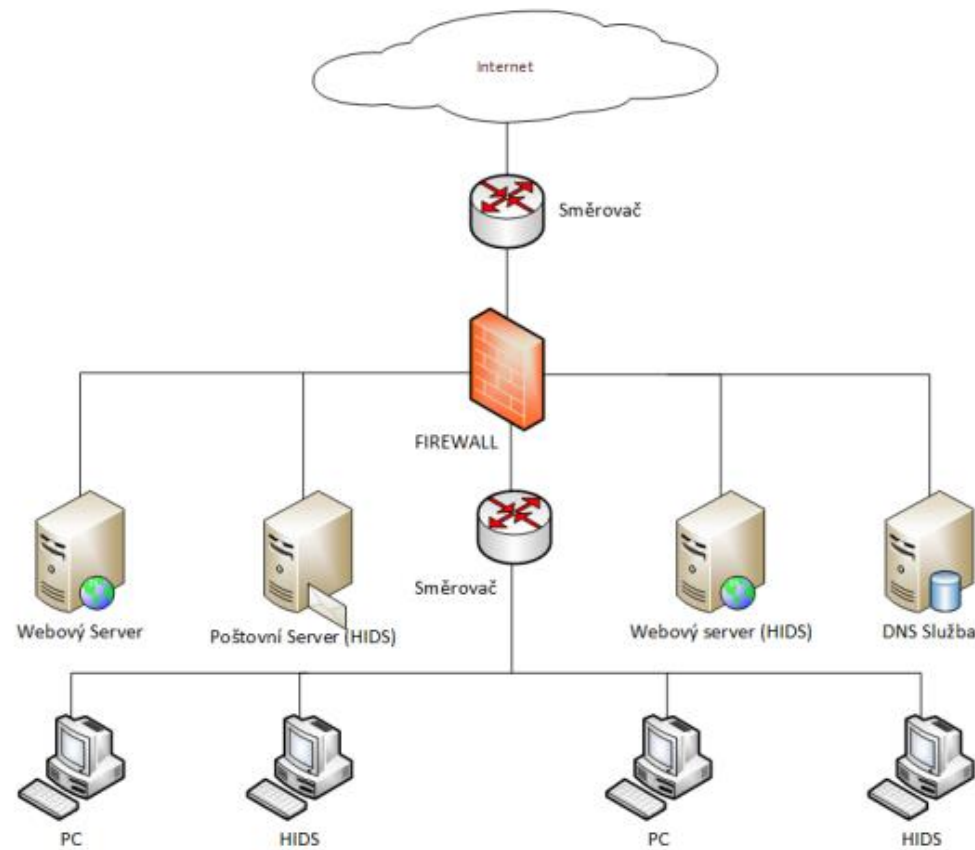
IDS

- Překonaná technologie, bez preventivního účinku
 - Útok se prožene sítí dříve, než si ho člověk všimne
 - Objem událostí bývá obrovský
- Přetrvávající smysl
 - Výzkum, statistiky provozu (sledování určitého typu událostí)
 - Inspekce v menších segmentech s méně událostmi
 - Sonda pro korelující distribuovaný systém

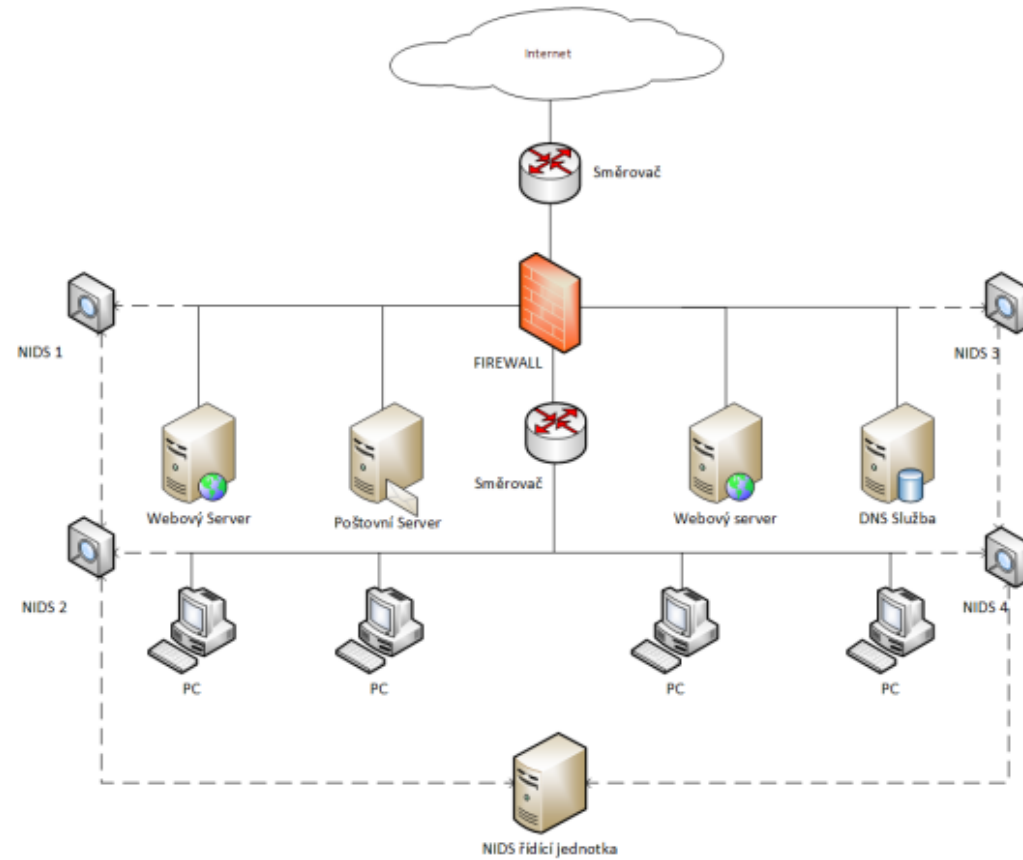
Network intrusion detection system (NIDS)



Host intrusion detection system (HIDS)



Distributed intrusion detection system (DIDS)



IPS

- Aktivně chrání síť
 - Závažné incidenty jsou blokovány
 - Méně závažné monitorovány
 - „Provinilé“ IP adresy lze umístit do karantény
 - Karanténu lze sdílet prostřednictvím reputační databáze
 - Spolupráce s NMS, přesun stanic do karanténní VLAN, zrušení 802.1X autentizace, apod.

Princip sledování

- I[DP]S – Provádí hloubkovou inspekci paketů
 - Sleduje především payload paketů
 - S hledáním jde až do aplikační vrstvy
 - Koreluje současný provoz s „nedávným“, vidí souvislosti
- Provoz sleduje
 - V síti (NIDS)
 - Na serveru / stanici (HIDS)

Práce IDS a IPS

- I[DP]S nahlíží do provozu
 - Běžného
 - Tunelovaného
 - Šifrovaného
 - Klonování provozu VPN před zabalením
 - Úložiště privátních klíčů
- Hledání
 - Exploitů, skenování, porušení firemních pravidel, distribuovaných útoků

Inspekce provozu

- Hledání signatur
 - Obdoba vyhledávání řetězců antivirem
 - Vícestupňové hledání
 - Zmenšuje latenci
 - Nejprve krátký řetězec
 - Je-li nalezen, následuje důkladnější kontrola
- Stavové hledání
 - Několik navazujících hledání v rámci komunikace

Detekce anomálií

- Nezvyklá komunikace v síti
 - Špatná délka zprávy, nesprávné kontrolní součty
 - Neobvyklý obsah zprávy
 - Nenavazující data v rámci komunikace
 - Datagramy nepatřící žádnému spojení
- Síťový provoz vymykající se normálu
 - Navzorkování „běžné“ komunikace
 - Statistické porovnání s běžným stavem

Detekce sadou pravidel

- Nejsofistikovanější inspekce vyspělejších zařízení
 - Korelace událostí, simulace lidského uvažování (fuzzy logic)
 - Schopnost nalézt i velmi nenápadné průniky
 - Odhalení „Zero Day“ útoků

Zásah IPS

- Pokud filtr zjistí bezpečnostní událost
 - Nahlásí ji (jako IDS)
 - Zablokuje datový tok
 - Umístí útočníka do karantény
 - Povolí provoz (white listing)
 - Omezí datový tok (sníží přenosové pásmo)
 - Přesměruje datový tok do jiné VLAN
 - Zásah na síťovém prvku přes NMS
 - Kombinace

Karanténa a reputace

- Lokální karanténa
 - IP adresy na kterých byl proveden nedávný zásah
 - Může být sdílena dalšími uživateli IPS / IDS
- Reputační databáze
 - Sdílený seznam problémových IP adres a DNS adres
- Při přístupu uživatele prohlížečem na adresu v karanténě dojde k přesměrování na stránku s upozorněním
- Zásah IPS pokud je
 - Komunikováno s IP adresou v lokální karanténě
 - Komunikováno s IP adresou z reputační databáze
 - Použita závadná DNS adresa z reputační databáze

K čemu IDS a IPS neslouží

- K monitorování služeb v síti
- K omezení přístupu, autorizace
- K antivirová ochrana
- K zabezpečení síťové vrstvy a síťových protokolů
- Zamezení DDoS útokům
- K „špehování“ uživatelů

Implementace

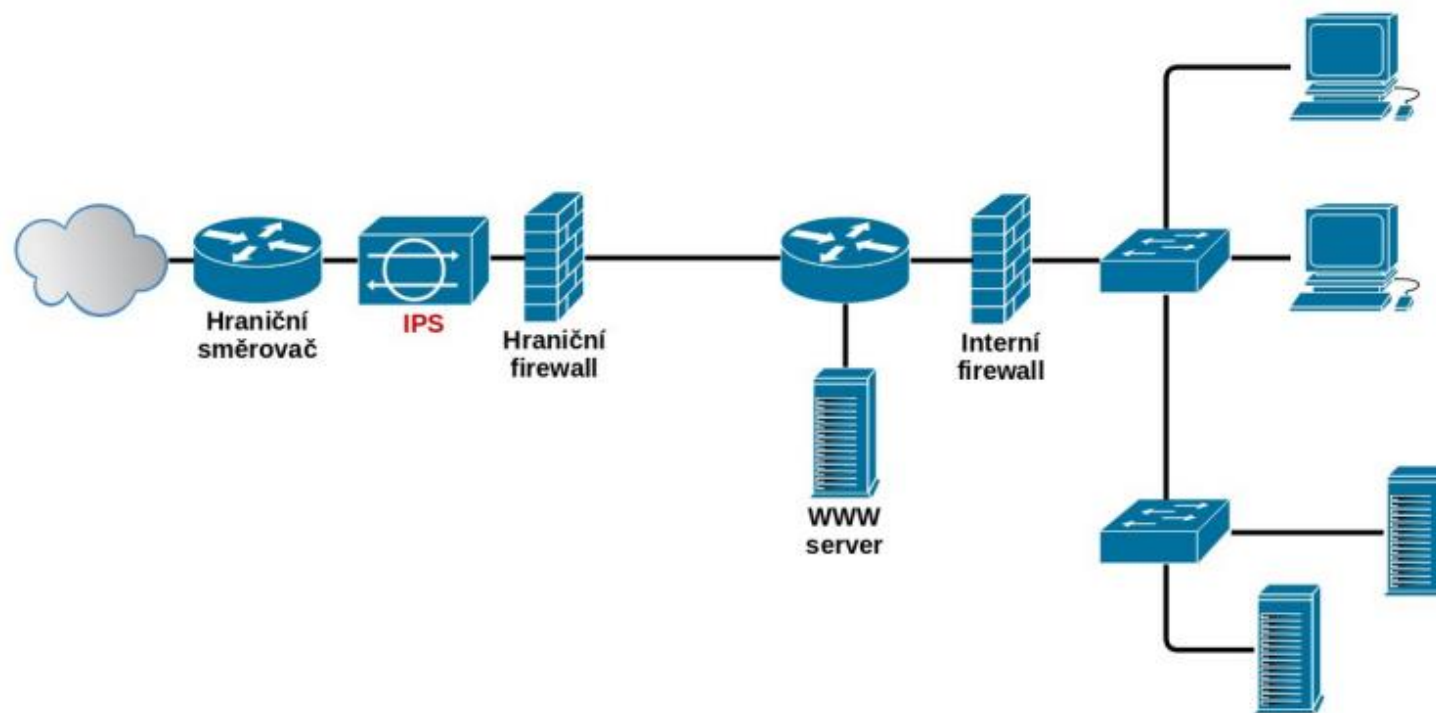
- IDS
 - PC s rychlou síťovou kartou, svobodný / placený SW
 - PC s HW kartou – sondou
 - HW IDS
- IPS
 - IDS software v režimu IPS (na Linuxu prostřednictvím IPTables a NFQueue)
 - Komerční řešení se softwarovou inspekcí
 - Firewall doplněný softwarovým IPS modulem
 - Kompletně hardwarové řešení s inspekcí realizovanou hradlovými poli a síťovými procesory

Nasazení

- Vně perimetru sítě
- Za první firewall
- Před síťový segment
 - Ochrana serverové farmy
 - Ochrana uživatelských stanic
- Sonda uvnitř sítě

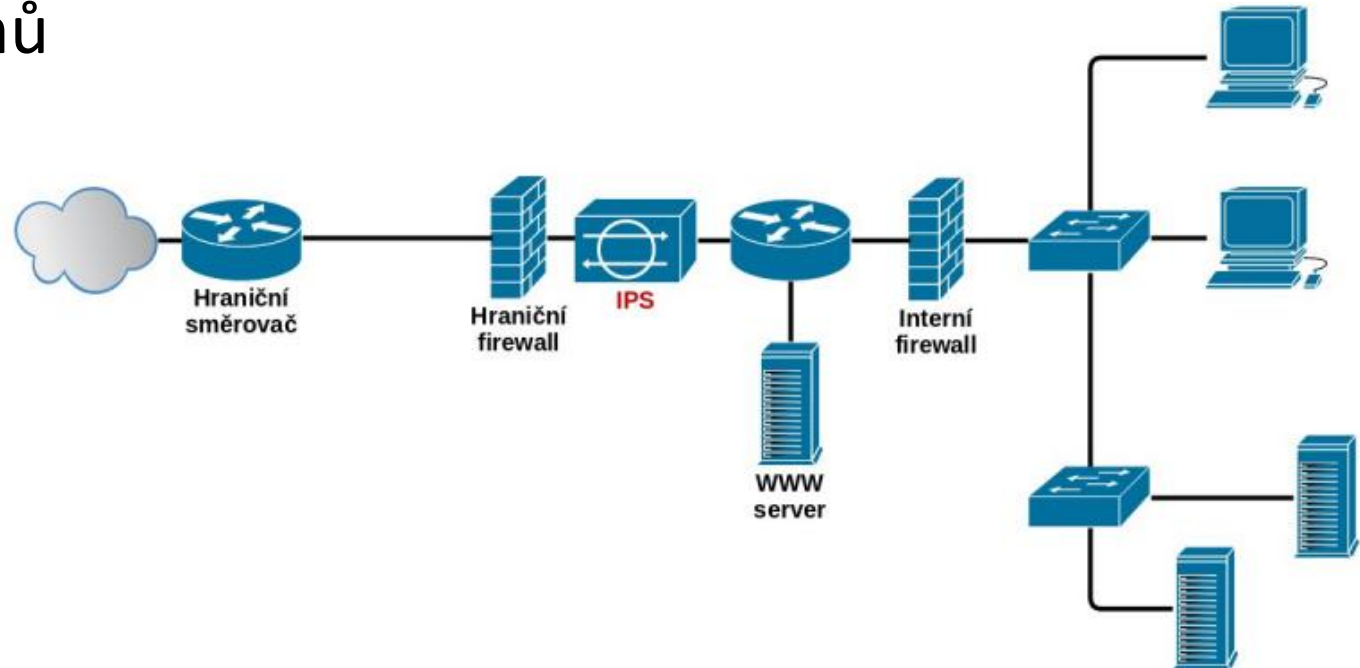
IPS před perimetrem

- Vidíme vše, co nás může ohrozit
- Značný provoz, nepřehledný monitoring
- Není obvyklé



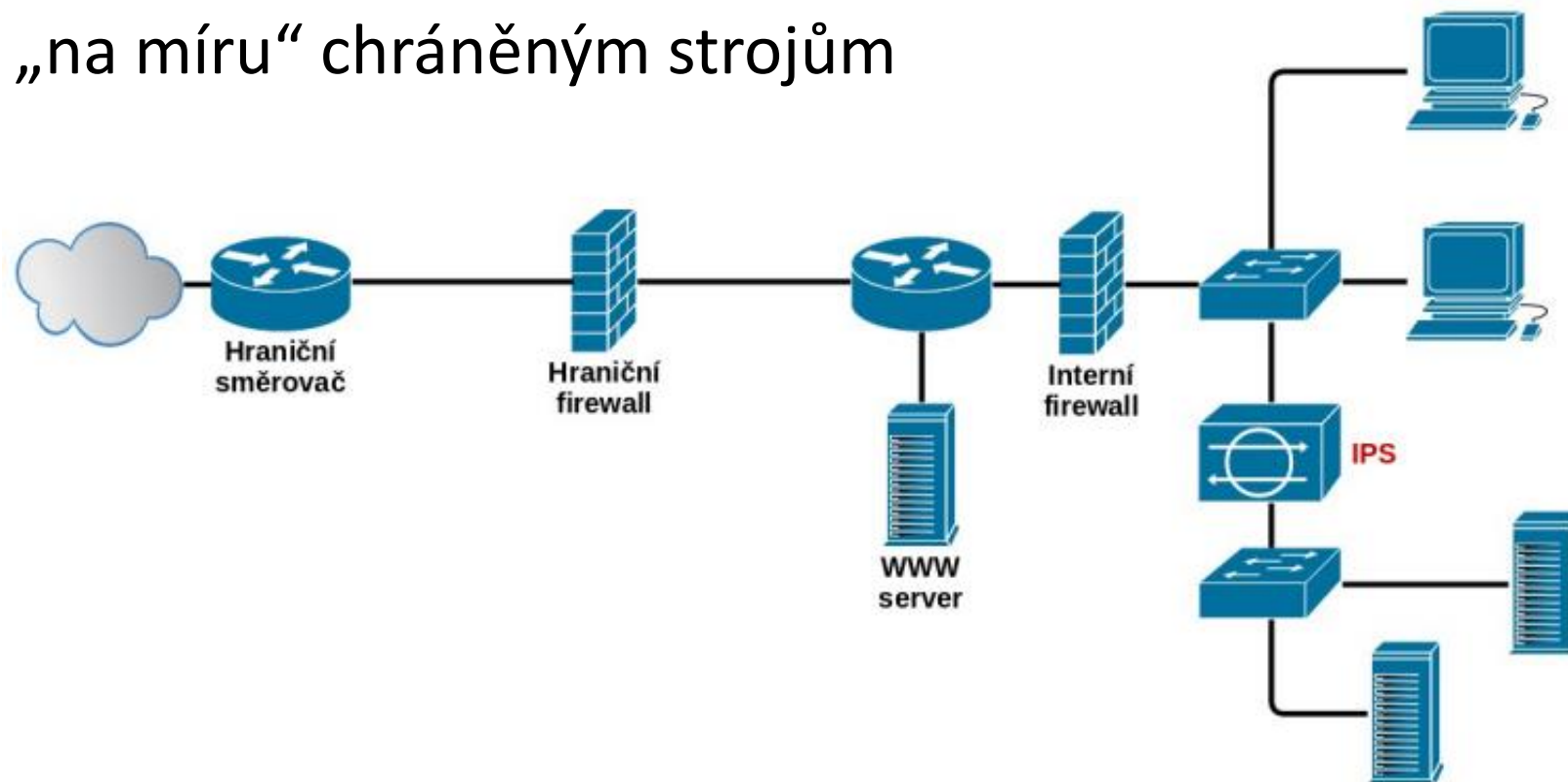
IPS před DMZ

- IPS je předřazen firewall
- Velké nároky na výkon inspekce
- Ochrana různých systémů
- Běžné nasazení



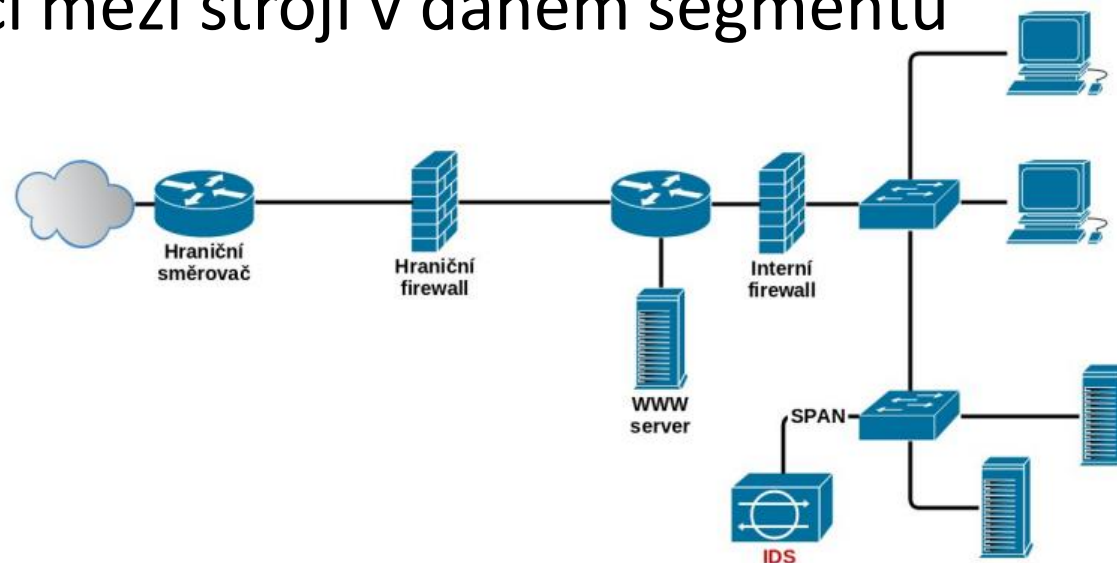
IPS před síťovým segmentem

- Menší provoz, nižší nároky na výkon inspekce
- Konfigurace IPS „na míru“ chráněným strojům



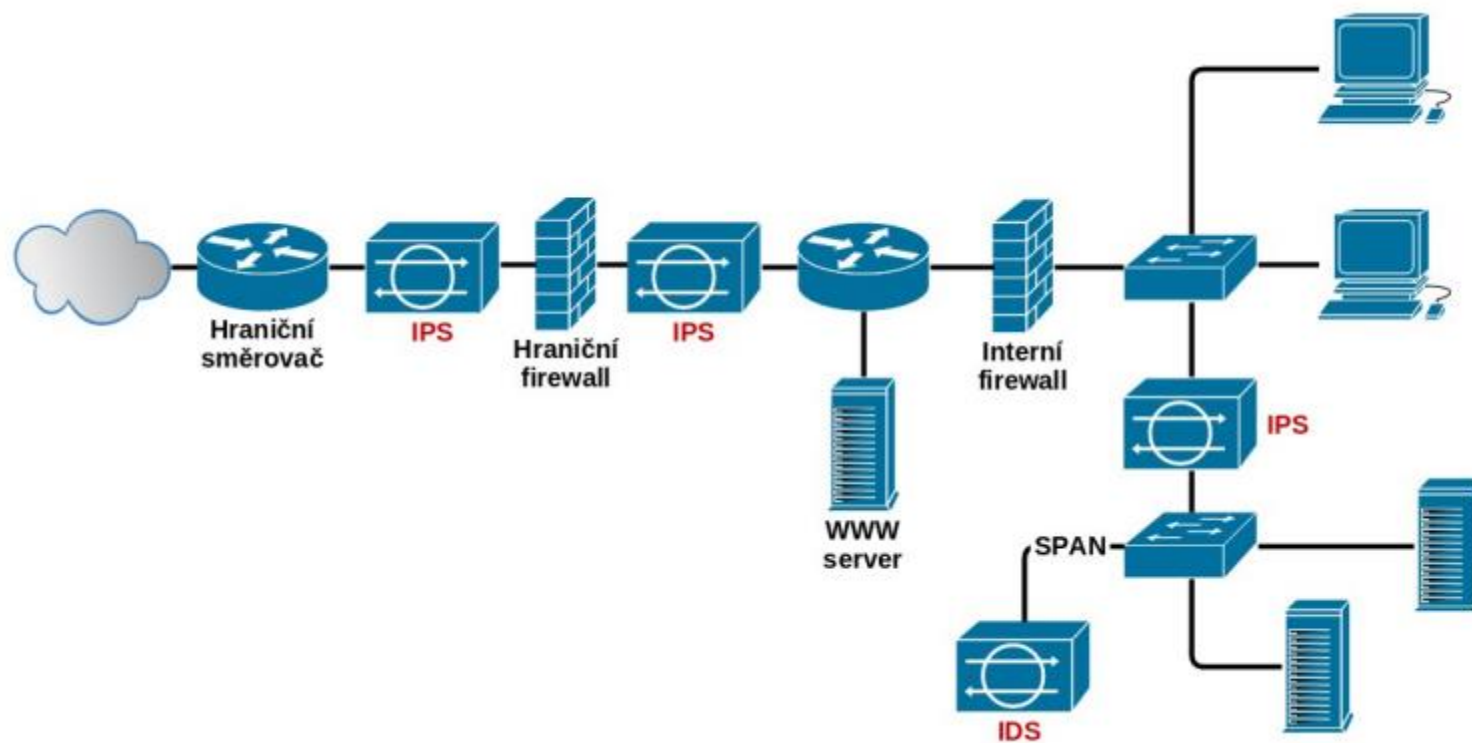
IDS sonda uvnitř sítě

- Sledování konkrétních anomálií v lokální síti
- Některé závadné chování se neprojeví, pokud je komunikace ovlivňována firewallem a IPS
- Nalezení problémů v komunikaci mezi stroji v daném segmentu



Více zařízení

- Nasazení IPS / IDS bývá kombinováno



Výběr komerčního produktu

- Kritéria pro výběr IPS
 - Propustnost
 - Výkon inspekce
 - Vysoká dostupnost
 - IPv6
 - Aktualizace firmware / pravidel / reputační databáze
 - Reakce na aktuální hrozby
 - Snadná správa, 365 / 7 / 24 podpora
 - Životnost zařízení
 - Certifikace (ICSA Labs, ...)
 - Recenze
 - Testování

Nasazení zařízení

- Prvotní konfigurace a „vyladění“ vyžaduje mnoho času
 - Příprava uživatelů
 - Analýza sítě
 - Úklid v síti
 - Instalace
 - Konfigurace
 - Výběr pravidel
 - Sledování provozu
 - Optimalizace zásahů pravidel, propojení s infrastrukturou



Nesnáze s uživateli

- Uživatelé se mohou bouřit
 - Je to „blackbox“, nemáme nad tím žádnou moc
 - „budu omezován“
 - „budu špehován“
 - „nechci svá data posílat NSA“
 - „co když to přestane fungovat“
- V provozu může být jakýkoliv problém svalen na IPS a jeho správce

SW řešení

- Nechci / nemohu investovat do HW řešení
 - Méně výkonné komerční produkty
 - SW IPS na bázi PC bez HW akcelerace inspekčního procesu
 - Bezplatné SW IDS / IPS sondy
 - Snort
 - Suricata
 - Sagan
- Sada pravidel
 - Vytvářených komunitou
 - Placených, dodávaných tvůrci

Snort

- Vyvíjen již od roku 1998
- Nyní produkt firmy Cisco
- Nyní zdarma, otevřený kód
- Stále jednovláknový (do verze 3)
- Několik sad pravidel
 - Existují komunitní pravidla zdarma
 - Kvalitní pravidla nutno koupit
 - Pro firmu cca 10.000 Kč ročně / senzor
 - Možnost vytvářet vlastní pravidla
- Pracuje v režimech
 - HIDS, NIDS, HIPS i NIPS



Suricata

- Finančně podporována vládou USA
- Vícevláknová, větší inspekční výkon (až 10Gbps)
- Automatická detekce protokolů a typů souborů
- Vyvíjena od roku 2009
- Opensource
- Menší komunita
- Pravidla
 - Snort
 - Ne všechna lze nainportovat
 - Komunitní
 - Placená
 - Vlastní



Konfigurace a monitoring

- HW IPS
 - Většinou vzdálený přístup přes WWW rozhraní, JAVA konzolí nebo dedikovaným systémem pro současnou správu více IPS zařízení (HW zařízení nebo virtuální stroj)
- SW I[DP]S
 - Lokální konfigurační soubory
 - Monitoring WWW aplikacemi třetích stran
 - Data předávána přes spooler a následně přes MySQL databázi
 - Barnyard2 (spooler)
 - BASE
 - Snorby

Konfigurace pravidel

- Nejlepší praxe:
 - Provoz bez falešných zásahů má mít vždy přednost před bezpečností
 - Příliš „utažená“ pravidla způsobují falešná pozitiva
 - Profily ladíme postupně
 - Nová pravidla nejprve vyzkoušíme v režimu „upozornění“
 - Jakmile jsme si jisti, že nevytvářejí falešná pozitiva, dáme je do režimu blokování

Zprovoznění IPS Suricata

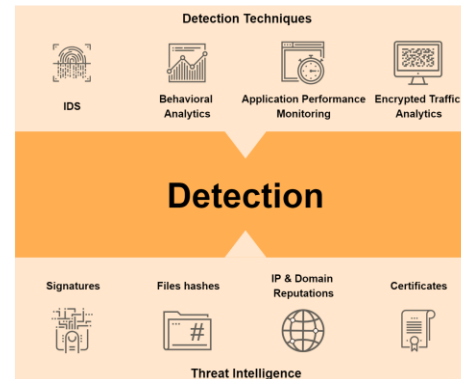
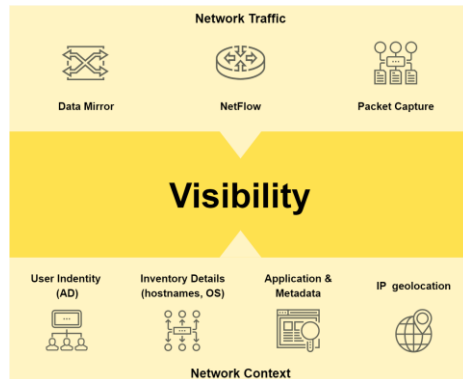
- Postup instalace v TXT souboru instalace_suricata.txt
 - síťový disk K:\Kurzy KB\KB III\IDS_IPS

Ukázka SELKS

- S - Suricata IDPS/NSM - <https://suricata.io/>
- E - Elasticsearch - <https://www.elastic.co/products/elasticsearch>
- L - Logstash - <https://www.elastic.co/products/logstash>
- K - Kibana - <https://www.elastic.co/products/kibana>
- S - Scirius - <https://github.com/StamusNetworks/scirius>
- EveBox - <https://evebox.org/>
- Arkime - <https://arkime.com/>
- CyberChef - <https://github.com/gchq/CyberChef>
- <https://10.60.63.202/>
 - username: selks-user
 - password: selks-user

Ukázka GREYCORTEx Mendel

- <https://www.greycortex.com/cs>



- <https://gcxa.teleinformatika.eu>
 - username: studentXX
 - password: Tele!nformatika_StudentXX
 - XX odpovídá číslu pracoviště/PC, čísla od 01 do 15

SIEM SYSTEMY

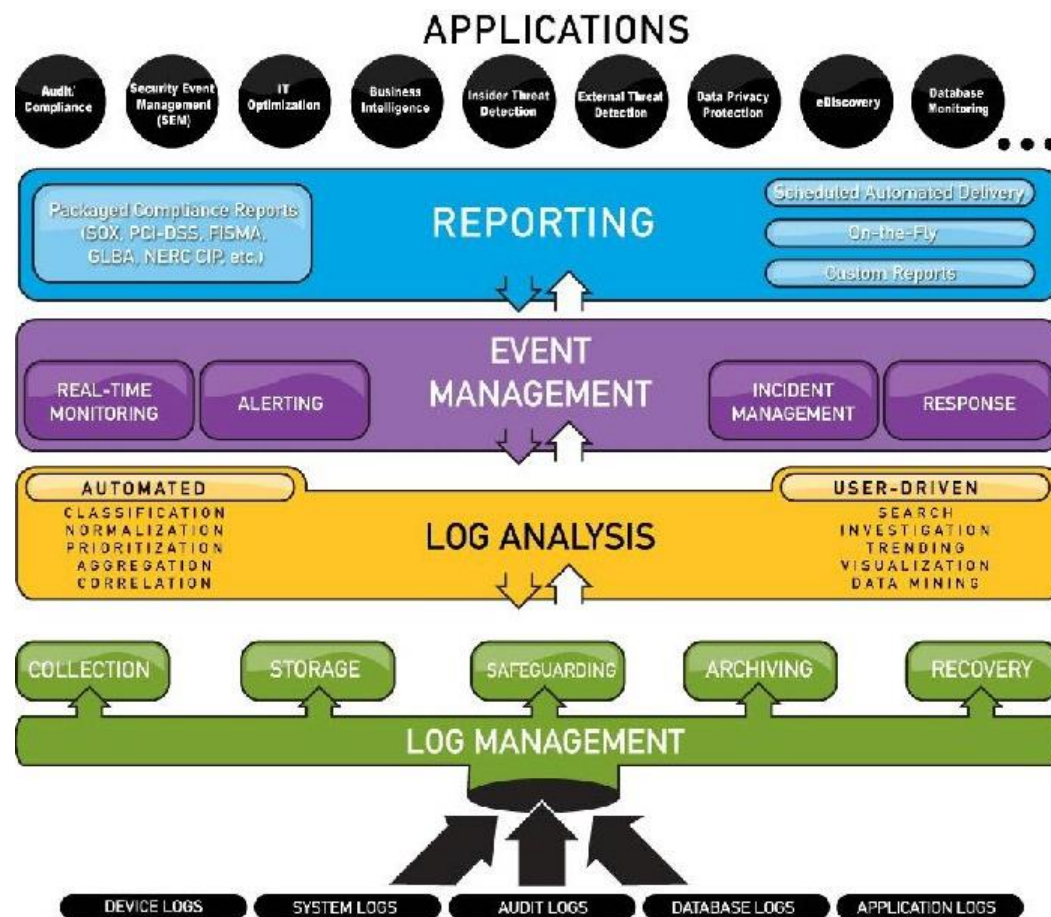
Od log managementu k SIEM

- Když surové logy nestačí
- Rozsáhlé prostředí
- Korelace v reálném čase
- Eliminace nutnosti náhledu do více konzolí
- Dodatečná indexace
- Efektivní směřování potřebných událostí
- Efektivní reporting

Hlavní funkce SIEM

- Kolekce
- Agregace
- Normalizace
- Filtrace
- Korelace
- Notifikace
- Archivace
- Retence
- Reporting

Architektura SIEM



Architektura SIEM

- Vše v jednom
 - Nižší cena HW i SW
 - Menší propustnost
 - Menší škálovatelnost
- Modulární
 - Možnost škálování
 - Větší propustnost
 - Vyšší nároky na HW
 - Vysoká dostupnost
 - Efektivnější provozní odezva
- Kombinace s modulární
 - Větší propustnost
 - Vyšší cena HW i SW

Gartner - Magický kvadrant pro SIEM



Základní podpůrné nástroje SIEM

- Testování na zranitelnosti
 - Pravidelné automatizované kontroly pomocí VA nástrojů
 - Penetrační testy při nasazení, nebo při zásadních změnách
- Evidence adresního prostoru
 - Rychlá identifikace zdroje na síti
 - Aktualizace z centrální evidence
 - Klasifikace segmentu
- Evidence systémů
 - Vkládání dodatečných informací o systému do incidentů
 - Fyzické umístění
 - Organizační jednotka
 - Správce systému
 - Klasifikace systémů

Pokročilé podpůrné nástroje SIEM

- **IAM** - identity a access management
 - Efektivní řízení přístupů dle nastavených pravidel
 - Sledování anomálií a odchylek v přístupech
 - Aktuální zobrazení informací:
 - Systém – kdo je přihlášen do systému a z jakého zdroje
 - Účet – kde všude je účet přihlášen a z jakého zdroje
- **NBAD** - detekce anomálií v síťovém provozu L3<
 - Umístění sondy na úrovni L2, nebo mirror portu
 - Sledování odchylek v chování pro:
 - zdroje a cíle spojení
 - počty spojení
 - četnost vytváření spojení
 - přenesený objem dat pro protokoly
 - časy aktivit

Pokročilé podpůrné nástroje SIEM

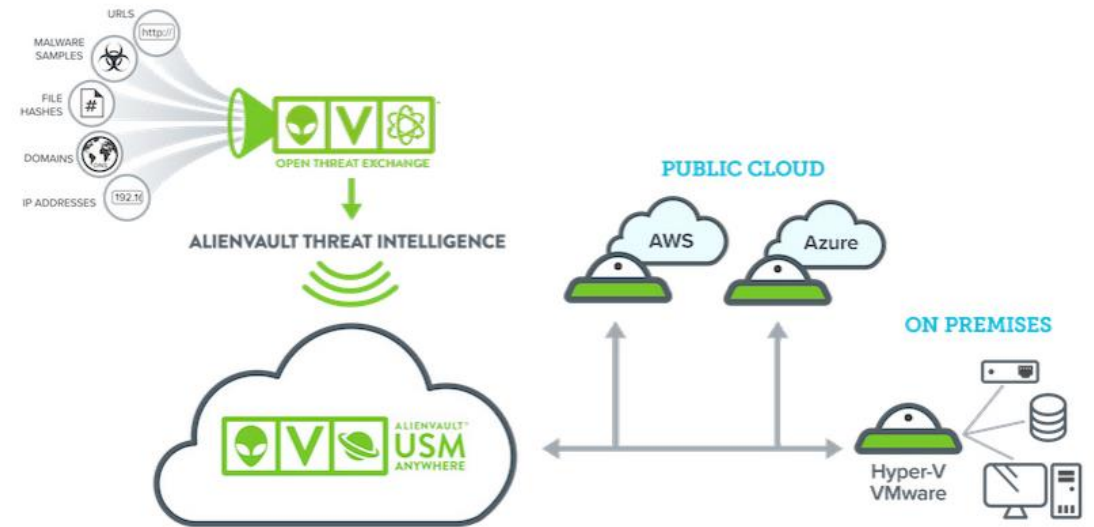
- **Sandboxing** – runtime analýza
 - Příchozí soubory z internetu - MTA, WWW, FTP
 - Analýza potencionálně infikovaných souborů
 - Zpětná analýza událostí v případě detekce anomálie
 - DNS, IP, ASN, URL
- **Darknet**
 - Alokovaný síťový prostor
 - Dříve neadresovaný prostor
 - Jakýkoliv paket je anomálie
- **Implementace principů honeypotů**
 - Honeytoken
 - Nativní honeypoty
 - Emulované honeypoty
 - V kombinaci s Darknet

Nejčastější chyby v nasazení LM nebo SIEM

- Neexistuje implementace log managementu
- Log management se řeší až v případě incidentu
- Průběžně se neověřuje obsah shromažďovaných událostí
- Malé retenční doby
- Malá propustnost řešení
- Neexistují krizové scénáře

AlienVault USM x OSSIM

- Unified Security Management (USM)
 - Placená verze
 - Plná podpora orchestrace
 - „Chudší“ databáze
- Open Source Security Information Management (OSSIM)
 - Open-source
 - Není log management
 - Chybí podpora cloudových služeb
- <https://cybersecurity.att.com/products/ossim/compare>

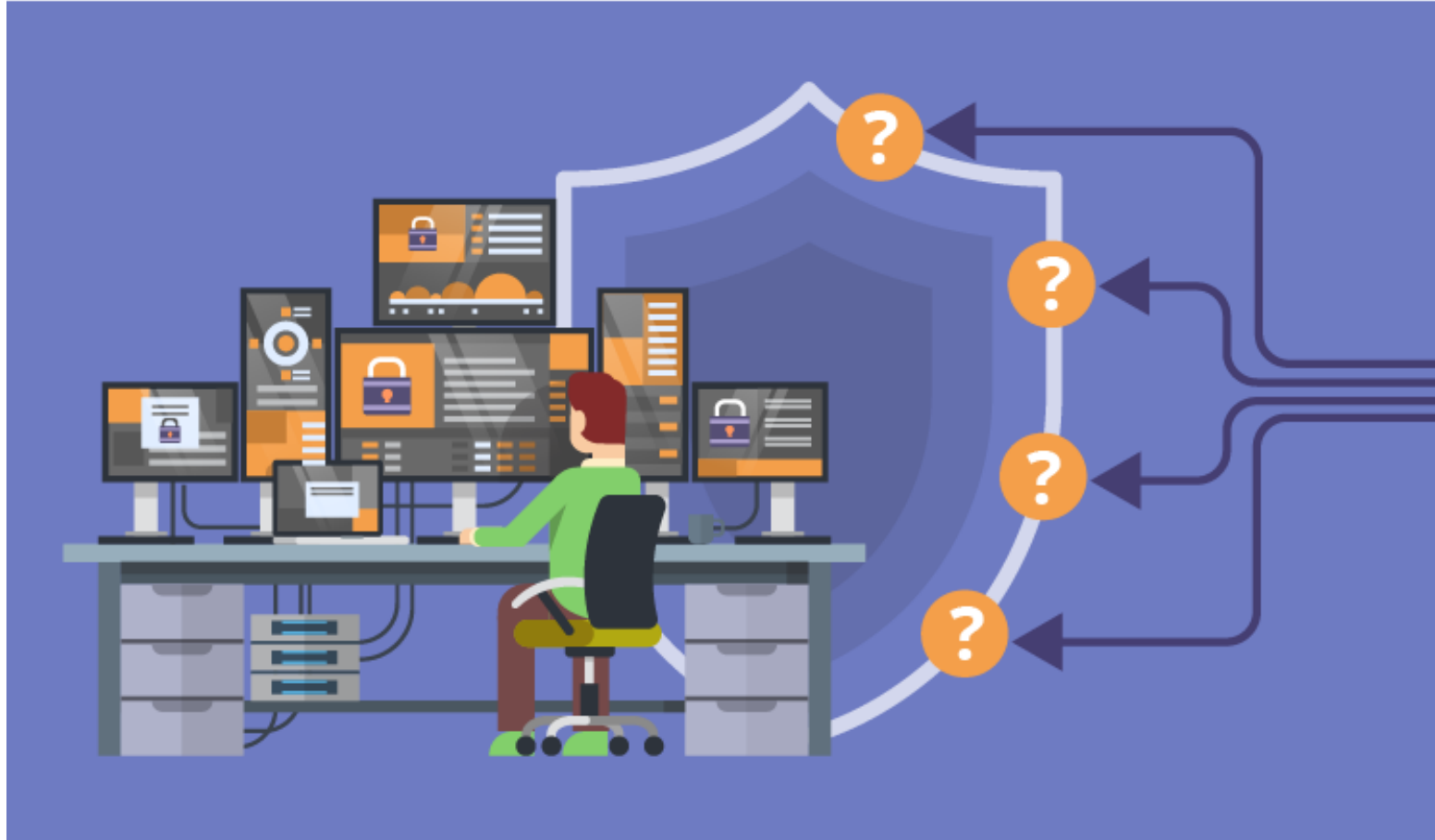


Ukázka SEIM AlienVault USM

- <https://siem.teleinformatika.eu/>
 - username: student**XX**
 - password: Tele!nformatika_Student**XX**
 - **XX** odpovídá číslu pracoviště/PC, čísla od 01 do 15

PENETRAČNÍ TESTOVÁNÍ

Penetrační testování



Typy penetračních testů

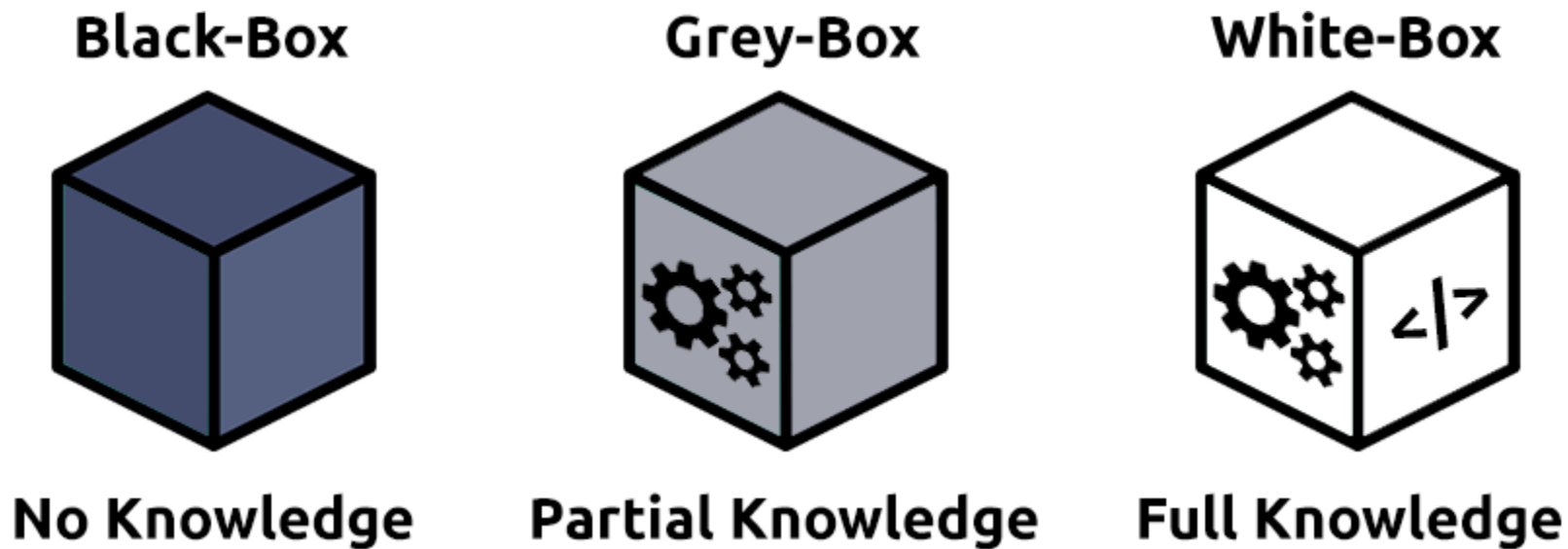
- Podle role testera
- Podle množství informací o testovaném systému
- Podle informovanosti zaměstnanců testované organizace
- Podle cíle testu

Podle role testera

- Externí
- Interní

Podle množství dostupných informací o testovaném systému

- Black-box
- White-box
- Grey-box



Podle informovanosti zaměstnanců testované organizace

- Ohlášené (se spoluprací)
- Neohlášené

Podle cíle testu

- Webové aplikace – detailní zaměření pouze na aplikaci
- Mobilní aplikace, wifi sítě, autentizační mechanismy, ...
- Testy oddělených sítí (technická síť)
- Specifické zařízení (IP telefonie, automaty, SCADA, ...)
- Testy nastavení IDS/IPS mechanismů

Fáze penetračního testování

- Určení rozsahu penetračního testování
- Výběr poskytovatele
- Příprava (účty, prostupy, oznámení, ...)
- Testování
- Závěrečná zpráva
- Vyhodnocení testu
- Závěrečná schůzka
- Odstranění nálezů

Testování

- **Plánování a průzkum** – tato fáze se skládá z pasivního a aktivního získávání informací o objednateli. Výstupem jsou rozsahy IP adres a informace o zaměstnancích (např. telefonní čísla, e-mailové adresy).
- **Skenování** – jedná se o proces testování cílené stanice se záměrem získání užitečných informací, které by mohly být využity v pozdějších fázích testování.
- **Enumerace** – je proces extrahování informací z cíleného systému z důvodu získání bližšího určení specifikací systému. Výstupem této fáze mohou být uživatelé a skupiny, sdílené složky, jména strojů atd.
- **Zisk přístupu** – jedná se o komplexní fázi, která se dělí do více kroků jako lámání hesel ke kompromitaci účtu, eskalování privilegií z běžného uživatele na administrátora apod.

Běžné problémy u penetračního testování

- Snaha vydávat sken zranitelností za penetrační testování
- Nekompetentní poskytovatel (nebo tester)
- Nedokončená práce
- Špatný odhad rozsahu testu
- Nadhodnocování/podhodnocování nálezů
- Termíny (např. nedodržení termínu, špatně zvolený termín)
- Není dodržena nezávislost testerů
- Zásahy administrátorů do průběhu testování
- Vyjmutí důležitých prvků z testování
- Nedostatečná komunikace v rámci organizace nebo s testery.

Rizika spojená s průběhem penetračního testování

- Při provádění automatizovaných testů může dojít k odmítnutí služby (DoS) nebo k omezení provozu
- Pád systému
- Zahlcení sítě
- Spuštění tiskáren
- Při testování autentizace může dojít k zablokování účtů
- Získání přístupu do systému a k získání citlivých dat
- Získání přístupu jako reálný uživatel nebo administrátor
- Nestandardní chování aplikace
- Nechtěná aktivita (např. e-maily zákazníkům)
- Průnik do cizích systémů (dodavatelé, soukromé, VPN, ...)
- Aktivace bezpečnostních mechanismů aplikace/firewallu (může dojít k zaslání oznámení administrátorovi)
- Zaplnění logovacího systému
- Poškození/zahlcení prvku nacházejícím se mezi útočícím a testovaným systémem
- Ztráta nebo znehodnocení dat
- Tvorba fiktivních registrací
- Shromažďování osobních údajů a jejich zpracovávání pro potřeby řádného provedení penetračního testování
- Při nedostatečné komunikaci může v organizaci nastat panika

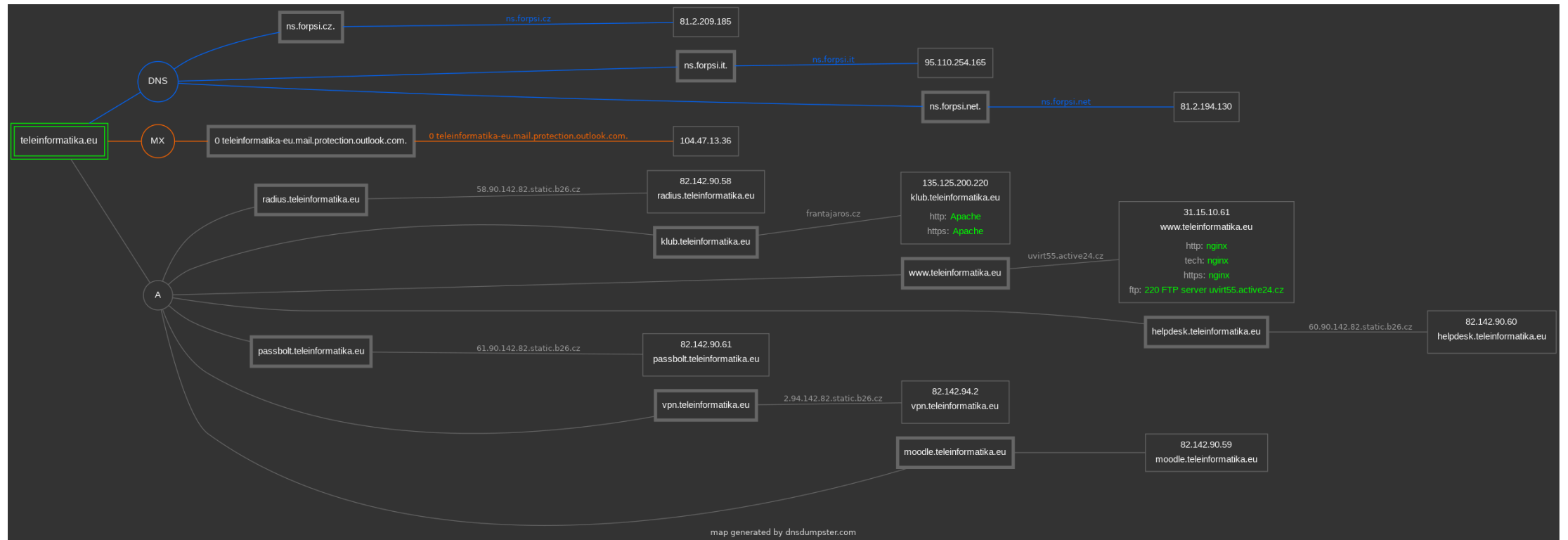
Metodologie

- The Open Source Security Testing Methodology Manual (OSSTMM)
 - <https://www.isecom.org/OSSTMM.3.pdf>
- Open Web Application Security Project (OWASP)
 - <https://owasp.org/>
- NIST Cybersecurity Framework
 - <https://www.nist.gov/cyberframework>
- Cyber Assessment Framework
 - <https://www.ncsc.gov.uk/collection/caf/caf-principles-and-guidance>

ZÍSKÁVÁNÍ DAT A JEJICH ANALÝZA

DNSDumpster

- <https://dnsdumpster.com/>



Shodan

- <https://www.shodan.io/>

 SHODAN

Explore

Downloads

Pricing 

port:23 country:CZ



Account

TOTAL RESULTS

4,802

TOP CITIES

Prague	2,172
Brno	166
Ostrava	137
České Budějovice	111
Pilsen	86

More...

TOP ORGANIZATIONS

O2 Czech Republic, a.s.	349
Vodafone Czech Republic a.s.	120
T-Mobile Czech Republic a.s.	115
SITKOM spol. s r.o.	112
Nordic Telecom Regional s.r.o.	106

More...

TOP PRODUCTS

Cisco router telnetd	171
OpenSSH	110
Microsoft ftpd	5
Dropbear sshd	2
Hikvision IP Camera	2

More...

 View Report

 Download Results

 Historical Trend

 View on Map

Partner Spotlight: Looking for a place to store all the Shodan data? Check out [Gravwell](#)

213.29.113.179 213-29-113-179.customers.tmcz.cz reselling MMO Cetin PH1  Czechia, Prague	MikroTik v6.45.5 (stable) Login:	2023-02-13T18:57:53.616942
109.107.218.187 Vodafone Czech Republic a.s.  Czechia, Prague	Router login:	2023-02-13T18:49:38.616843
80.250.12.172 cmb-czfacility.eu Starman Bohemia spol. s r.o.  Czechia, Prague	Synaccess Inc. Telnet Session V6.2.	2023-02-13T18:49:25.646275
81.92.159.62 CoProSys a.s. Backbone  Czechia, Prague	\r\n%connection closed by remote host!	2023-02-13T18:48:28.415277
46.183.56.89 89.56.lipnet.net Nordic Telecom Regional s.r.o.  Czechia, Lipnik nad Bečvou	API_Hunkova login:	2023-02-13T18:44:23.906305
185.131.62.29 SITKOM spol. s r.o.  Czechia, Kladno	MikroTik v6.45.7 (stable) Login:	2023-02-13T18:25:12.657050
93.190.62.135 62135.fastportnet.cz	Login:	2023-02-13T18:22:43.807594

urlscan

- <https://urlscan.io/>

www.teleinformatika.eu

2a02:4a8:ac24:110::10:61

Submitted URL: <http://teleinformatika.eu/>

Effective URL: <https://www.teleinformatika.eu/>

Submission: On February 13 via manual (February 13th 2023, 8:23:18 pm UTC) from [CZ](#) — Scanned from [DE](#)

[Summary](#) [HTTP 48](#) [Redirects](#) [Links 6](#) [Behaviour](#) [Indicators](#) [Similar](#) [DOM](#) [Content](#) [API](#) [Verdicts](#)

Summary

This website contacted 10 IPs in 3 countries across 10 domains to perform 48 HTTP transactions. The main IP is 2a02:4a8:ac24:110::10:61, located in Czech Republic and belongs to GLOBE-AS [www.active24.cz](#), CZ. The main domain is [www.teleinformatika.eu](#). TLS certificate: Issued by R3 on December 15th 2022. Valid for: 3 months.

This is the only time [www.teleinformatika.eu](#) was scanned on urlscan.io!

urlscan.io Verdict: No classification

Live information

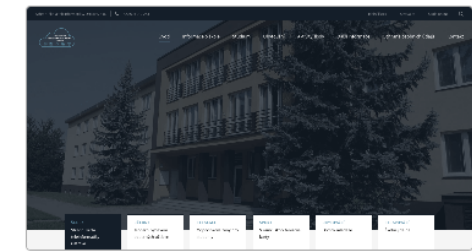
Google Safe Browsing: No classification for [www.teleinformatika.eu](#)

Current DNS A record: 31.15.10.61 (AS25234 - GLOBE-AS [www.active24.cz](#), CZ)

Domain & IP Information

IP/ASNs	IP Detail	Domains	Domain Tree	Links	Certs	Frames
IP Address AS Autonomous System						
2 → 38	2a02:4a8:ac24:110::10:61			25234 (GLOBE-AS www.active24.cz)		
1	2a00:1450:400d:806::2008			15169 (GOOGLE)		
1	2a00:1450:400d:806::2002			15169 (GOOGLE)		
2	2a00:1450:400d:806::200e			15169 (GOOGLE)		
1 → 1	2a02:598:c:189::43			43037 (SEZNAM-)		
2	2a02:598:a::79:234			43037 (SEZNAM-)		
2	2a03:2880:f02d:12:face:b00c:0:3			32934 (FACEBOOK)		
1	2a00:1450:400d:80a::2004			15169 (GOOGLE)		
1	2a00:1450:400d:80a::2003			15169 (GOOGLE)		
2	2a03:2880:f12d:83:face:b00c:0:25de			32934 (FACEBOOK)		
48				10		

Screenshot



Page URL History

1. <http://teleinformatika.eu/> HTTP 301
<https://teleinformatika.eu/> HTTP 301
<https://www.teleinformatika.eu/> Page URL

Detected technologies

WordPress (CMS)	Expand
Facebook (Widgets)	Expand
Font Awesome (Font Scripts)	Expand
Google Analytics (Analytics)	Expand
Google Tag Manager (Tag Managers)	Expand

Page Statistics

48	98 %	100 %	10	11
Requests	HTTPS	IPv6	Domains	Subdomains
10	3	3775 kB	5707 kB	7
IPs	Countries	Transfer	Size	Cookies

Abuse

- <https://abuse.ch/>

PhishTool

- <https://www.phishtool.com/>

ZDROJE INFORMACÍ V KYBERNETICKÉ BEZPEČNOSTI

MITRE ATT&CK

- Platformu, která shromažďuje a kategorizuje různé typy strategií, technik a postupů, které používají kybernetičtí útočníci.
- Platforma pomáhá firmám najít slabiny v jejich vlastní kybernetické obraně.

MITRE ATT&CK

Reconnaissance	Resource Development	Initial Access	Execution	Persistence	Privilege Escalation	Defense Evasion	Credential Access	Discovery	Lateral Movement	Collection	Command and Control	Exfiltration	Impact
10 techniques	7 techniques	9 techniques	12 techniques	19 techniques	13 techniques	40 techniques	15 techniques	29 techniques	9 techniques	17 techniques	16 techniques	9 techniques	13 techniques
Active Scanning (2)	Acquire Infrastructure (6)	Drive-by Compromise	Command and Scripting Interpreter (8)	Account Manipulation (4)	Abuse Elevation Control Mechanism (4)	Abuse Elevation Control Mechanism (4)	Adversary-in-the-Middle (2)	Account Discovery (4)	Exploitation of Remote Services	Adversary-in-the-Middle (2)	Application Layer Protocol (4)	Automated Exfiltration (1)	Account Access Removal
Gather Victim Host Information (4)	Compromise Accounts (2)	Exploit Public-Facing Application	Container Administration Command	BITS Jobs	Access Token Manipulation (5)	Access Token Manipulation (5)	Brute Force (4)	Application Window Discovery	Internal Spearphishing	Archive Collected Data (9)	Communication Through Removable Media	Data Transfer Size Limits	Data Destruction
Gather Victim Identity Information (3)	Compromise Infrastructure (6)	External Remote Services	Deploy Container	Boot or Logon Autostart Execution (13)	Boot or Logon Autostart Execution (13)	BITS Jobs	Credentials from Password Stores (5)	Browser Bookmark Discovery	Lateral Tool Transfer				Data Encrypted for Impact
Gather Victim Network Information (6)	Develop Capabilities (4)	Hardware Additions	Exploitation for Client Execution	Boot or Logon Initialization Scripts (5)	Boot or Logon Initialization Scripts (5)	Build Image on Host	Exploitation for Credential Access	Cloud Infrastructure Discovery	Remote Service Session Hijacking (2)	Audio Capture	Data Encoding (2)	Exfiltration Over Alternative Protocol (3)	Data Manipulation (3)
Gather Victim Org Information (4)	Establish Accounts (2)	Phishing (3)	Inter-Process Communication (2)	Browser Extensions	Create or Modify System Process (4)	Deobfuscate/Decode Files or Information	Forced Authentication	Cloud Service Discovery	Remote Services (6)	Automated Collection	Data Obfuscation (3)	Exfiltration Over C2 Channel	Defacement (2)
Phishing for Information (3)	Obtain Capabilities (6)	Replication Through Removable Media	Native API	Compromise Client Software Binary	Domain Policy Modification (2)	Deploy Container	Forge Web Credentials (2)	Cloud Storage Object Discovery	Replication Through Removable Media	Browser Session Hijacking	Dynamic Resolution (9)	Exfiltration Over Other Network Medium (1)	Disk Wipe (2)
Search Closed Sources (2)	Stage Capabilities (5)	Supply Chain Compromise (3)	Scheduled Task/Job (6)	Create Account (3)	Domain Policy Modification (2)	Direct Volume Access	Input Capture (4)	Container and Resource Discovery	Software Deployment Tools	Clipboard Data	Encrypted Channel (2)	Exfiltration Over Physical Medium (1)	Endpoint Denial of Service (4)
Search Open Technical Databases (5)		Trusted Relationship	Shared Modules	Create or Modify System Process (4)	Escape to Host	Execution Guardrails (1)	Modify Authentication Process (4)	Domain Trust Discovery	Taint Shared Content	Data from Cloud Storage Object	Fallback Channels	Exfiltration Over Web Service (2)	Firmware Corruption
Search Open Websites/Domains (2)		Valid Accounts (4)	Software Deployment Tools	Event Triggered Execution (15)	Event Triggered Execution (15)	Exploitation for Defense Evasion	Network Sniffing	File and Directory Discovery	Use Alternate Authentication Material (4)	Data from Information Repositories (3)	Ingress Tool Transfer	Scheduled Transfer	Inhibit System Recovery
Search Victim-Owned Websites			System Services (2)	External Remote Services	Hijack Execution Flow (11)	File and Directory Permissions Modification (2)	OS Credential Dumping (8)	Network Service Scanning		Data from Configuration Repository (2)	Multi-Stage Channels	Transfer Data to Cloud Account	Network Denial of Service (2)
			User Execution (3)	Hijack Execution Flow (11)	Process Injection (11)	Hide Artifacts (9)	Steal Application Access Token	Network Share Discovery		Data from Local System	Non-Application Layer Protocol	Transfer Data to Cloud Account	Resource Hijacking
			Windows Management Instrumentation	Implant Internal Image	Scheduled Task/Job (6)	Hijack Execution Flow (11)	Steal or Forge Kerberos Tickets (4)	Network Sniffing		Data from Network Shared Drive	Protocol Tunneling		Service Stop
				Modify Authentication Process (4)	Valid Accounts (4)	Indicator Removal on Host (6)	Steal Web Session Cookie	Password Policy Discovery		Data from Removable Media	Proxy (4)		System Shutdown/Reboot
				Office Application Startup (6)		Indirect Command Execution	Two-Factor Authentication Interception	Peripheral Device Discovery		Permission Groups Discovery (3)	Remote Access Software		
				Pre-OS Boot (5)		Masquerading (7)	Unsecured Credentials (7)	Process Discovery		Data Staged (2)	Traffic Signaling (1)		
				Scheduled Task/Job (6)		Modify Authentication Process (4)		Query Registry		Email Collection (3)	Web Service (3)		
				Server Software Component (4)		Modify Cloud Compute Infrastructure (4)		Remote System Discovery		Input Capture (4)			
				Traffic Signaling (1)		Modify Registry		Software Discovery (1)		Screen Capture			
				Valid Accounts (4)		Network Boundary Bridging (1)		System Information Discovery		Video Capture			
						Obfuscated Files or Information (8)		System Location Discovery (1)					
						Pre-OS Boot (5)		System Network Configuration Discovery (1)					
						Process Injection (11)		System Network Connections Discovery					
						Reflective Code Loading		System Owner/User Discovery					
						Rogue Domain Controller		System Service Discovery					
						Rootkit		System Time Discovery					
						Signed Binary Proxy Execution (13)		Virtualization/Sandbox Evasion (3)					
						Signed Script Proxy Execution (11)		Weaken Encryption (2)					
						Subvert Trust Controls (6)		XSL Script Processing					
						Template Injection							
						Traffic Signaling (1)							
						Trusted Developer Utilities Proxy Execution (1)							
						Unused/Unsupported Cloud Regions							
						Use Alternate Authentication Material (4)							
						Valid Accounts (4)							
						Virtualization/Sandbox Evasion (3)							
						Weaken Encryption (2)							
						XSL Script Processing							

MITRE ATT&CK

- Kategorie:
 - Prvotní přístup
 - Exekuce
 - Perzistence
 - Eskalace privilegií
 - Způsoby obejití obrany
 - Přístup k citlivým datům
 - Průzkum
 - Sběr dat
 - C&C
 - Exfiltrace
 - Následky

MITRE ATT&CK

- Matrice:
 - Enterprise
 - Mobile
 - ICS

MITRE ATT&CK

- <https://mitre-attack.github.io/attack-navigator/>

AI V KYBERNETICKÉ BEZPEČNOSTI

Cisco TALOS

- V současnosti asi největší databáze Threat Intelligence
- <https://www.talosintelligence.com/>



OpenAI

- <https://chat.openai.com/>

Využití OpenAI pro tvorbu pravidel v Suricatě

- `alert tcp $EXTERNAL_NET any -> $HOME_NET 23 (msg:"TELNET connection"; flow:established,to_server; content:"|FF FB 01|"; depth:3; reference:cve,2010-0423; classtype:attempted-administrator; sid:10000001; rev:1;)`

BU

vytvoř pravidlo alert pro systém suricata detekující telnet provoz



Zde je příklad pravidla alert pro systém Suricata, který detekuje provoz Telnet:



CSS

Copy code

```
alert tcp $EXTERNAL_NET any -> $HOME_NET 23 (msg:"TELNET connection"; flow:established
```

Tento příklad pravidla kontroluje výstup z aplikace na portu 23 (standardní port Telnet), a pokud najde obsah "|FF FB 01|", upozorní na to pomocí hlášení "TELNET connection". Další položky v pravidle, jako je flow, content, depth a reference, slouží k vymezení kontextu a dalšího významu detekce.

Využití OpenAI pro tvorbu pravidel v Suricatě

- `alert http $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (msg:"Access to example.com detected"; flow:to_server,established; content:"example.com"; http_host; reference:url,example.com; classtype:web-application-activity; sid:10000002: rev:1:)`

BU

vytvoř pravidlo pro detekci webové stránky `http://example.com` v systému suricata



Zde je příklad pravidla alert pro systém Suricata, který detekuje přístup k webové stránce "`http://example.com`":



CSS

Copy code

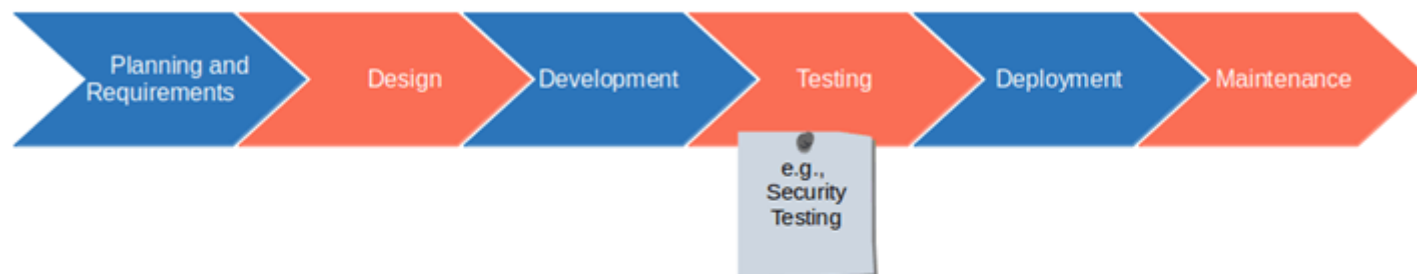
```
alert http $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (msg:"Access to example.com detected";
```

Tento příklad pravidla kontroluje výstup HTTP na portech definovaných jako `$HTTP_PORTS`, a pokud najde obsah "example.com" v položce `http_host`, upozorní na to pomocí hlášení "Access to example.com detected". Další položky v pravidle, jako je flow a reference, slouží k vymezení kontextu a dalšího významu detekce.

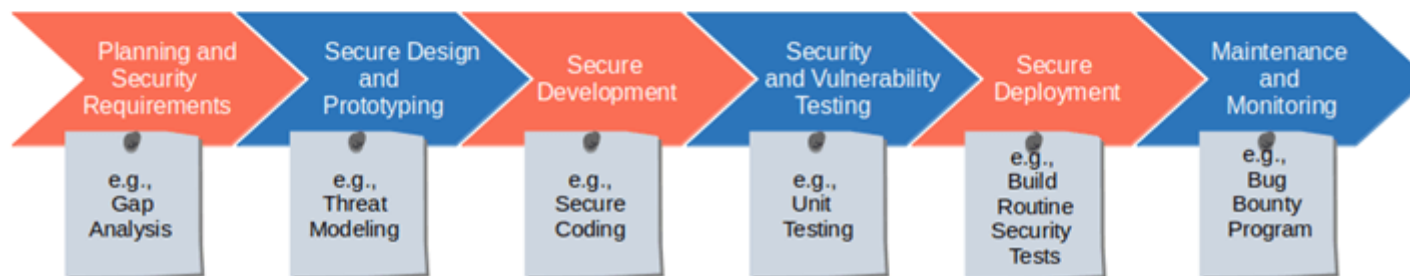
BEZPEČNÉ PROGRAMOVÁNÍ

Bezpečný kód

Software Development Life Cycle (SDLC) Process

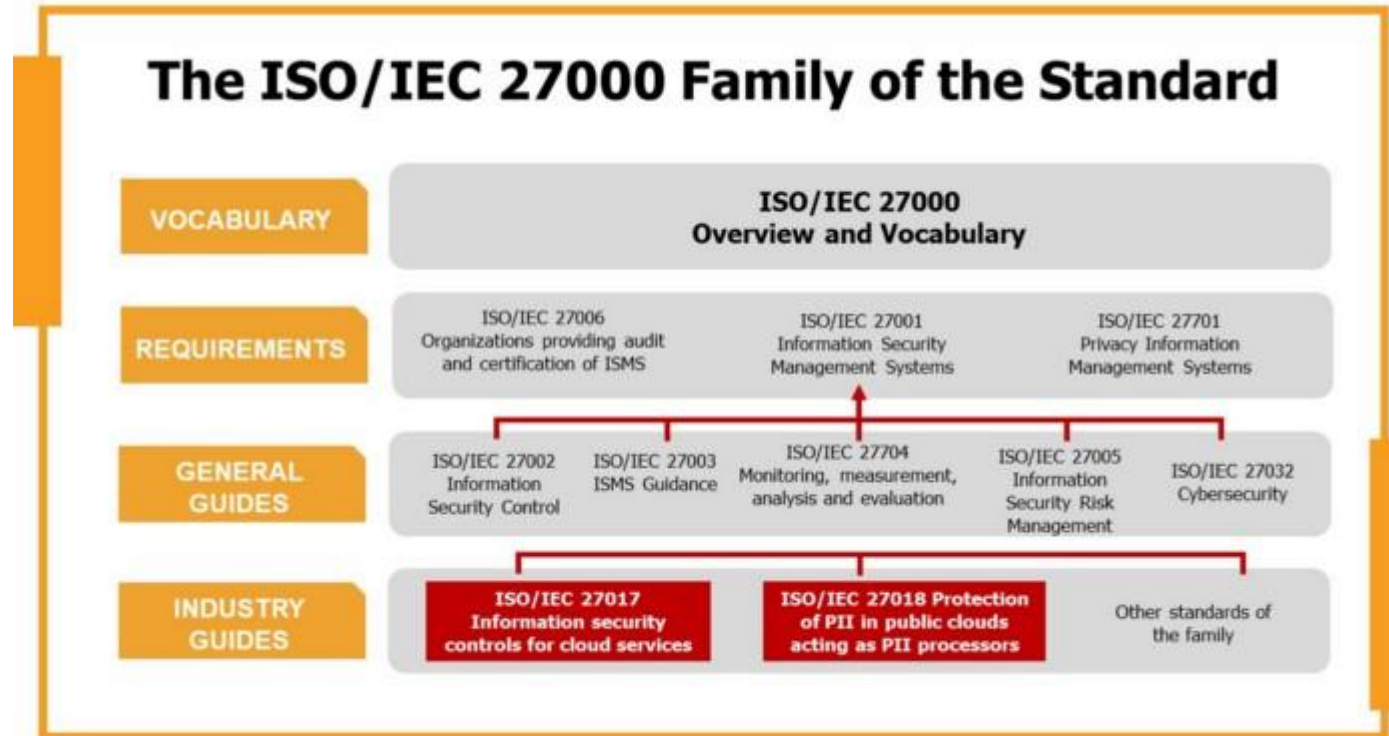


Secure Software Development Life Cycle (SSDLC) Process



STANDARD ISO/IEC 27000

Standard ISO/IEC 27001



PROSTOR PRO VAŠE DOTAZY

DĚKUJI VÁM ZA POZORNOST